

INCIDENT RESPONSE PLAN

Hypothetical Security Breach Response

Prepared by: Nandhini Devi D

Date: 27 September 2026

1. Executive Summary

This Incident Response Plan (IRP) establishes a structured, repeatable process for detecting, containing, eradicating, and recovering from a cybersecurity incident within a mid-sized organization ("the Company"). It is built around a hypothetical scenario — a ransomware infection originating from a phishing email that leads to unauthorized access, lateral movement, and encryption of file-server data — and generalizes the response steps so the same plan applies to most breach types (malware, unauthorized access, data exfiltration, denial of service, or insider misuse).

The plan follows the incident-handling lifecycle defined in NIST SP 800-61 Rev. 2 (Preparation, Detection & Analysis, Containment/Eradication/Recovery, and Post-Incident Activity) and incorporates practices from the SANS Incident Handler's Handbook and ISO/IEC 27035. It defines team roles, communication protocols, technical response procedures, legal and regulatory considerations, and preventive controls to reduce the likelihood and impact of future incidents.

Hypothetical Scenario Used Throughout This Plan

An employee in the Finance department opens a malicious attachment in a phishing email. The attachment installs a credential-stealing trojan, which is used to move laterally to a file server over the weekend. Ransomware is deployed, encrypting shared financial and HR data. A ransom note demands payment in cryptocurrency within 72 hours. On Monday morning, users report that shared drives are inaccessible and files have a new ".locked" extension.

2. Purpose, Scope, and Objectives

2.1 Purpose

To provide the organization with a clear, actionable, pre-approved process for responding to security incidents in a way that minimizes damage, reduces recovery time and cost, and preserves evidence for investigation and potential legal action.

2.2 Scope

This plan applies to all information systems, networks, applications, and data owned or operated by the Company, and to all employees, contractors, and third parties with access to those systems. It covers incidents including but not limited to:

- Malware and ransomware infections
- Unauthorized access or account compromise
- Data breaches and data exfiltration
- Denial-of-service (DoS/DDoS) attacks
- Insider threats and misuse of privileged access
- Physical security breaches affecting IT assets

2.3 Objectives

1. Detect and confirm incidents as early as possible.

2. Contain the incident to limit damage and prevent spread.
3. Eradicate the root cause and any residual attacker access.
4. Restore normal operations safely and verifiably.
5. Preserve evidence to support root-cause analysis and, where needed, law enforcement involvement.
6. Meet legal, regulatory, and contractual notification obligations.
7. Capture lessons learned and improve defenses to prevent recurrence.

3. Incident Response Team (IRT) and Roles

A cross-functional Incident Response Team is activated for any confirmed incident above a Low severity rating (see Section 4). Roles are defined in advance so responsibilities are clear during a high-stress event.

Role	Primary Responsibility	Example Owner
Incident Commander (IC)	Overall decision authority; coordinates the response; declares severity; approves containment actions	IT Security Manager
Security Analyst / Handler	Technical investigation, log analysis, containment and eradication execution	SOC Analyst
IT Operations Lead	System restoration, backups, infrastructure changes	Systems Administrator
Communications Lead	Internal updates, customer/partner notifications, media handling	Corporate Communications
Legal Counsel	Regulatory obligations, breach notification law, law enforcement liaison	General Counsel / External Counsel
HR Representative	Insider-threat cases, employee-related actions	HR Business Partner
Executive Sponsor	Business impact decisions, budget approval, ransom/payment decisions	CIO / CISO

A current on-call roster with names and 24/7 contact information should be maintained separately in the IR team's access-controlled shared location and reviewed quarterly (see Appendix A).

4. Incident Severity Classification

Severity determines escalation speed, who is notified, and which procedures apply.

Level	Definition	Example	Response Time
Critical (SEV-1)	Widespread impact; core business systems down or sensitive data confirmed exfiltrated	Ransomware encrypting production/finance servers	Immediate — IRT activated within 30 min
High (SEV-2)	Significant but contained impact; single system or department affected	Compromised admin account, contained malware	Within 1 hour
Medium (SEV-3)	Limited impact; suspicious activity requiring investigation	Phishing click with no confirmed compromise	Within 4 hours

Level	Definition	Example	Response Time
Low (SEV-4)	Minimal or no impact; policy violation or blocked attack	Blocked malware attachment, failed login attempts	Within 1 business day

5. Incident Response Lifecycle

The response follows six phases, based on the NIST SP 800-61 model. Each phase below includes specific actions applied to the ransomware scenario introduced in Section 1.

5.1 Phase 1 — Preparation (Before an Incident)

Preparation happens continuously, before any incident occurs, so the organization can respond effectively when one does.

- Maintain an up-to-date asset inventory and network diagram.
- Deploy and tune endpoint detection and response (EDR), SIEM logging, and email/spam filtering.
- Maintain immutable, regularly tested offline/offsite backups (3-2-1 rule).
- Keep this IRP, contact lists, and playbooks current and accessible offline in case systems are encrypted.
- Run tabletop exercises and phishing simulations at least twice a year.
- Pre-establish relationships with a digital forensics firm, cyber-insurance provider, and legal counsel.
- Ensure all staff complete annual security awareness training.

5.2 Phase 2 — Identification (Detection & Analysis)

Goal: confirm whether an event is a genuine security incident and determine its scope.

8. Receive alert or report (SIEM/EDR alert, help-desk ticket, employee report of locked files).
9. Log the report in the incident tracking system with timestamp, reporter, and initial description.
10. Security Analyst performs triage: checks EDR/SIEM for related alerts, reviews affected system logs, and confirms indicators of compromise (IOCs) such as the ".locked" file extension, ransom note, or unusual outbound traffic.
11. Determine scope: which systems, accounts, and data are affected; how the attacker likely gained entry (in this case, the phishing email).
12. Assign a severity level (Section 4) and formally declare an incident.
13. Incident Commander activates the Incident Response Team and opens a secure communication channel (e.g., an out-of-band chat, since email may be compromised).

5.3 Phase 3 — Containment

Goal: stop the incident from spreading further while preserving evidence.

Short-term containment (immediate, within the first hour)

- Isolate affected endpoints and the file server from the network (disable network adapter or switch port; do not power off, to preserve memory evidence).

- Disable compromised user accounts and force a password reset for any accounts suspected of compromise.
- Block identified malicious IPs, domains, and file hashes at the firewall, proxy, and EDR.
- Preserve evidence: capture memory images and disk snapshots of affected systems before any remediation.
- Notify the Executive Sponsor and Legal Counsel of a confirmed Critical/High incident.

Long-term containment

- Rebuild or patch affected systems on an isolated network segment while the investigation continues.
- Deploy additional monitoring on adjacent systems to detect further lateral movement.
- Rotate credentials and secrets (service accounts, API keys) that may have been exposed.

5.4 Phase 4 — Eradication

Goal: remove the attacker's foothold and the root cause of the incident.

14. Identify and remove malware, backdoors, and unauthorized accounts or scheduled tasks from all affected systems.
15. Patch the exploited vulnerability (in this scenario: reinforce email attachment filtering and disable macro execution from the internet).
16. Confirm eradication using a second, independent scan (a different AV/EDR engine or manual forensic review) before proceeding to recovery.
17. Document every eradication action taken, with timestamps, for the post-incident report.

5.5 Phase 5 — Recovery

Goal: safely restore systems to normal operation and confirm the threat is fully removed.

- Restore encrypted or affected data from the most recent clean, verified backup — never restore from backups without first scanning them for reinfection.
- Rebuild severely compromised systems from known-good images rather than attempting to "clean" them in place.
- Reconnect systems to the network in stages, monitoring closely for recurrence of malicious activity.
- Reset passwords organization-wide if credential theft is confirmed or suspected.
- Validate business functionality with the affected departments (in this case, Finance and HR) before declaring recovery complete.
- Formally close the incident only after a defined monitoring period (e.g., 5–10 business days) with no recurrence.

5.6 Phase 6 — Post-Incident Activity (Lessons Learned)

Goal: turn the incident into an opportunity to strengthen defenses.

18. Hold a blameless post-incident review meeting within 5–10 business days of closure, including all IRT members.
19. Produce a formal incident report covering: timeline, root cause, actions taken, business impact (downtime, cost, data affected), and effectiveness of the response.

20. Identify and assign owners to corrective actions (e.g., "Deploy email attachment sandboxing — Owner: IT Security — Due: 30 days").
21. Update this IRP, playbooks, and detection rules based on findings.
22. Track corrective actions to completion in the IT risk register.

6. Legal, Regulatory, and Communication Considerations

6.1 Notification Obligations

Depending on jurisdiction and the type of data involved, the Company may be legally required to notify affected individuals, regulators, and/or law enforcement within a defined window (commonly 72 hours under regulations such as GDPR, or per applicable state/national breach-notification laws). Legal Counsel determines applicable obligations for each incident; the Communications Lead executes approved notifications.

6.2 Internal Communication

- Use a pre-agreed out-of-band channel (e.g., phone bridge or a messaging app outside the corporate network) if email or chat systems may be compromised.
- Share information on a need-to-know basis; avoid speculation in written communications that could later be discoverable.
- Provide regular status updates to executives (e.g., every 2–4 hours during a Critical incident).

6.3 External Communication

- All customer, partner, media, or regulator communication is reviewed by Legal and issued only by the Communications Lead or an authorized spokesperson.
- Do not confirm technical details externally until they are verified, to avoid retraction or liability.

6.4 Ransom Payment Considerations

Paying a ransom does not guarantee data recovery and may violate sanctions law in some jurisdictions. Any decision to consider payment requires Executive Sponsor and Legal Counsel approval, consultation with law enforcement, and engagement of a specialized negotiation/forensics firm. Recovery from verified backups is always the preferred path.

7. Preventive Measures and Future Hardening

The following controls directly address the root cause of the hypothetical scenario (phishing → credential theft → lateral movement → ransomware) and reduce the likelihood and impact of similar future incidents.

7.1 Technical Controls

- Advanced email filtering with attachment sandboxing and disabling of macros from external sources.

- Multi-factor authentication (MFA) enforced on all accounts, especially privileged and remote-access accounts.
- Network segmentation to limit lateral movement between departments and critical servers.
- Endpoint Detection and Response (EDR) with automated isolation capability on all endpoints and servers.
- Least-privilege access control and regular access reviews for shared drives and admin rights.
- Immutable, offline/air-gapped backups tested via regular restore drills.
- Timely patch management for operating systems and applications.

7.2 Administrative & Human Controls

- Mandatory, recurring security awareness training with simulated phishing campaigns.
- A clear, easy "report suspicious email" process with a one-click reporting button.
- Formal change-management and account-lifecycle processes (prompt deprovisioning of departed employees).
- Annual review and tabletop testing of this Incident Response Plan.

7.3 Monitoring & Continuous Improvement

- Centralized SIEM log collection with alerting tuned to the IOCs and TTPs observed in past incidents.
- Periodic penetration testing and vulnerability scanning.
- Threat-intelligence feeds integrated into detection tooling to catch known ransomware indicators early.

8. Appendices

Appendix A — Incident Response Contact Roster (Template)

Role	Name	Phone	Email	Backup Contact
Incident Commander	[TBD]	[TBD]	[TBD]	[TBD]
Security Analyst	[TBD]	[TBD]	[TBD]	[TBD]
IT Operations Lead	[TBD]	[TBD]	[TBD]	[TBD]
Legal Counsel	[TBD]	[TBD]	[TBD]	[TBD]
Communications Lead	[TBD]	[TBD]	[TBD]	[TBD]
Cyber Insurance Provider	[TBD]	[TBD]	[TBD]	—
External Forensics Firm	[TBD]	[TBD]	[TBD]	—
Local Law Enforcement / CERT	[TBD]	[TBD]	[TBD]	—

Appendix B — Incident Response Checklist (Quick Reference)

23. Detect and log the incident.
24. Assign severity and activate the IRT.
25. Isolate affected systems (contain).
26. Preserve evidence (memory/disk images, logs).
27. Identify root cause and remove threat (eradicate).
28. Restore from clean backups and validate (recover).
29. Notify legal/regulatory bodies as required.
30. Conduct post-incident review and update this plan (lessons learned).

Appendix C — Key Frameworks Referenced

- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
- SANS Incident Handler's Handbook
- ISO/IEC 27035 — Information Security Incident Management
- MITRE ATT&CK Framework (for mapping attacker techniques during analysis)